

Segurança e Governança em IA (OWASP Top 10)

CHEAT SHEET #03

Cheat Sheet de Vulnerabilidades, Defesas & Guardrails — SECOMP 2026

Principais Ameaças em Sistemas com LLM

Vulnerabilidade	Mecanismo de Ataque	Estratégia de Mitigação
Prompt Injection Direta	Usuário envia texto tentando sobrescrever o System Prompt.	Delimitadores XML estritos e higienização de inputs.
Prompt Injection Indireta	Instruções maliciosas escondidas em PDFs/sites lidos pelo RAG.	Verificação prévia do contexto recuperado com guardrails.
Data Leakage / PII	Exposição indevida de dados sigilosos armazenados no Vector DB.	Controle de acesso RBAC no Vector DB e anonimização de PII.
Excessive Agency	Agentes executando ações destrutivas sem aprovação.	Princípio do Menor Privilégio e Human-in-the-Loop (HITL).

Checklist de Produção (Go-Live Audit)

- [] **Guardrails Ativos:** Filtros de entrada e saída em milissegundos (NeMo Guardrails / Llama Guard).
- [] **Trilha de Auditoria:** Registros completos de traces e chamadas de ferramentas (Opik / LangSmith).
- [] **Princípio do Menor Privilégio:** Servidores MCP restritos com permissões mínimas de escrita/rede.
- [] **Conformidade LGPD:** Criptografia AES-256 em descanso e suporte a exclusão de dados do usuário.